The problem and today's controls

What we verify

Each user holds **entitlements** (access rights) and a declared role, the **FRC** (functional role code, 8 roles). Each entitlement lists the FRCs allowed to hold it.

$$\text{Violation} \Leftrightarrow \text{UserFRC} \notin \{\text{EntitlementFRCs}\}$$

The rule is deterministic, so the real question is whether the declared FRC is correct.

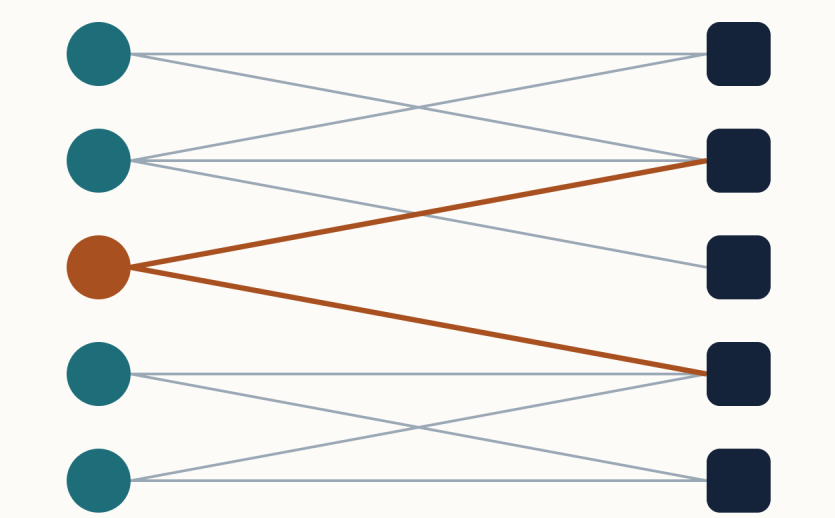
Current solution: compliance controls

Five if/else rules on the user's desk and cost centre, automated at the request of the compliance team.

≈2,000	of about 5,000 users are settled with certainty
5 of 8	FRCs are covered by the rules

About 3,000 users stay undecided, and the rules use organisational attributes, not the accesses.

Current work: Graph Neural Network



Edges are accesses : The red user has accesses that look like another FRC's, so their declared FRC is questioned

1 Graph

Users and entitlements as nodes, accesses as edges, with user attributes and authorised FRCs (amongst others) as features.

2 Model

Two GraphSAGE layers trained on the declared FRC, with class weights, label smoothing and dropout.

3 Score

Out-of-fold predictions (10 folds, 2 seeds): the loss of the declared FRC is the suspicion score of a user.

4 Review

Highest-loss users that the controls cannot settle or disagree on, plus random users as a reference, go to compliance.

Findings, open questions and next steps

FIRST COMPLIANCE REVIEW

TOP 20 BY LOSS

[3 / 20] declared FRC confirmed

[16 / 20] model FRC confirmed

RANDOM 20 (REFERENCE)

[19 / 20] declared FRC confirmed

[18 / 20] model FRC confirmed

Evolutions envisaged

- Show compliance the accesses that push against the declared FRC (interpretability)
- Tune the attribute dropout and the other regularisation settings of the model
- Compare with baselines (entitlement vote, LightGBM), add bundle nodes

Questions for the discussion

- How to learn from a target that is itself under audit without memorising its errors?
- How to evaluate without ground truth, beyond a top 20 versus random 20 review?
- How to force the use of a weak signal (accesses) against a strong shortcut (organisation)?